

Hochschule Niederrhein
University of Applied Sciences



Wirtschaftswissenschaften
Faculty of Business Administration
and Economics

BCSM 402 BCM

Kap. 08: ZERTIFIZIERUNG UND AUDITIERUNG DES BCMS

Prof. Dr. Gael Pentang

Gael.Pentang@hs-niederrhein.de

Sommersemester

BCSM 402 BCM

Kap. 08: ZERTIFIZIERUNG UND AUDITIERUNG DES BCMS

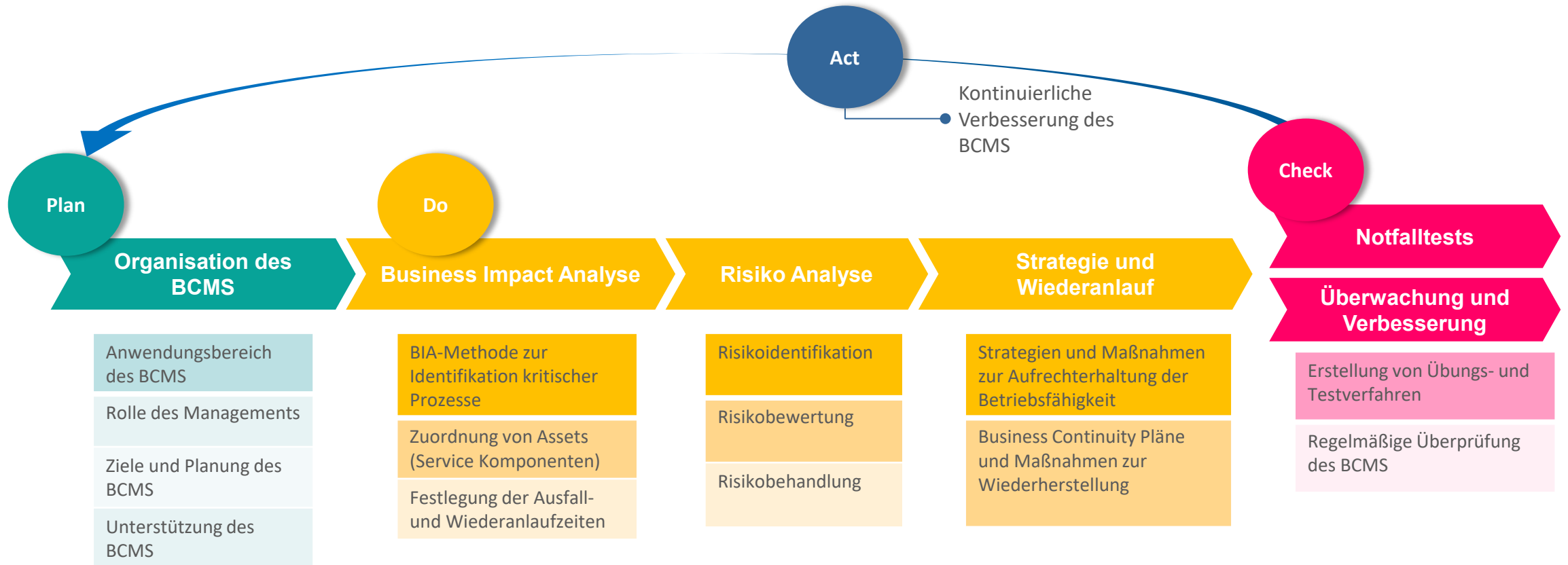
Prof. Dr. Gael Pentang

Gael.Pentang@hs-niederrhein.de

Sommersemester 2025 | Seminaristische Lehrveranstaltung

2. Gliederung

- Kapitel 00: Organisatorisches
- Kapitel 01: Grundlagen des Business Continuity Management (BCM)
- Kapitel 02: Standards und Rahmenbedingungen für BCM
- Kapitel 03: Rollen und Verantwortlichkeiten im BCM-Prozess
- Kapitel 04: Business Impact Analyse: Methoden und Techniken
- Kapitel 05: BCM Risikomanagement: Strategien und Umsetzung
- Kapitel 06: Betrieb & Leistungsüberprüfung und Verbesserung
- Kapitel 07: Krisenmanagement - Krisenübung
- **Kapitel 08: Zertifizierung und Auditierung des BCMS**
- Kapitel 09: IT-Service Continuity Management (ITSCM)



Am Ende sind Sie in der Lage, ...

- ✓ die Bedeutung und den Zweck der Auditierung eines BCMS zu verstehen,
- ✓ die erforderlichen Schritte zur Vorbereitung eines Zertifizierungsaudits für ein BCMS zu erklären,
- ✓ den Ablauf und die wichtigen Aspekte bei der Durchführung eines Zertifizierungsaudits für ein BCMS zu beschreiben,
- ✓ die Bedeutung der Berichterstattung im Zertifizierungsprozess zu erkennen und die erforderlichen Dokumente und Berichte zu erstellen,
- ✓ Nichtkonformitäten im Zertifizierungsprozess zu identifizieren, angemessene Maßnahmen zur Behebung vorzuschlagen und deren Auswirkungen zu verstehen.

- 1. Audit-Grundlagen**
- 2. Vorbereitung und Planung**
- 3. Audit Durchführung**
- 4. Berichtserstattung im Auditprozess**
- 5. Nichtkonformitäten**
- 6. Zusammenfassung**

- 1. Audit-Grundlagen**
- 2. Vorbereitung und Planung**
- 3. Audit Durchführung**
- 4. Berichtserstattung im Auditprozess**
- 5. Nichtkonformitäten**
- 6. Zusammenfassung**

8.1. Audit-Grundlagen

Definition

BCMS Audit

Überprüfung von Eignung und Umsetzung eines Business Continuity Management Systems nach ISO 22301

- Audits des BCMS werden entweder **freiwillig** oder aufgrund der **Anforderungen externer Interessensgruppen** durch die Institution angefordert
- Ziel ist die **Prüfung, ob das BCMS den Anforderungen anerkannter Standards** entspricht
- Methoden und Vorgehen richten sich nach Standards – **ISO 19011:2026** enthält Richtlinien für die Planung, Durchführung und Steuerung von Audits von Managementsystemen

8.1. Audit-Grundlagen

Auditarten

1st Party Audit (Intern)	2nd Party Audit (Lieferant)	3rd Party Audit (Zertifizierung)
Akteur: Interne Mitarbeiter (oder beauftragte Berater) Auftraggeber: Durchführung im Auftrag des Managements Ziel: Selbstprüfung, Systempflege & Vorbereitung auf Zertifizierungen	Akteur: Externe Partei mit berechtigtem Interesse (z.B. ein Kunde) Auftraggeber: Durchführung im Auftrag des Managements für eine externe Partei mit direktem Interesse (Organisation prüft Lieferanten) Ziel: Lieferkettensicherheit	Akteur: unabhängige Dritte (akkreditierte Zertifizierungsgesellschaft) Auftraggeber: Durchführung im Auftrag des Managements Ziel: Offizielle Zertifizierung nach ISO 22301

WICHTIG: Ein **Zertifizierungsaudit nach ISO 22301** ist immer ein strikt **zweistufiges Verfahren (Stage I & Stage II)**.

8.1. Audit-Grundlagen

Zweistufige Zertifizierungsarchitektur



Stage I Audit: Dokumentation & Theorie

Fokus: Steht das System auf dem Papier?

- **Aktivität:** Überprüfung der **grundsätzlichen Eignung** des BCMS für den Anwendungsbereich (*Scope*) anhand der vorhandene Dokumentation
- **Prüfmethode:** Review von Richtlinien, Prozesse, Risikobetrachtungen, Vollständigkeit



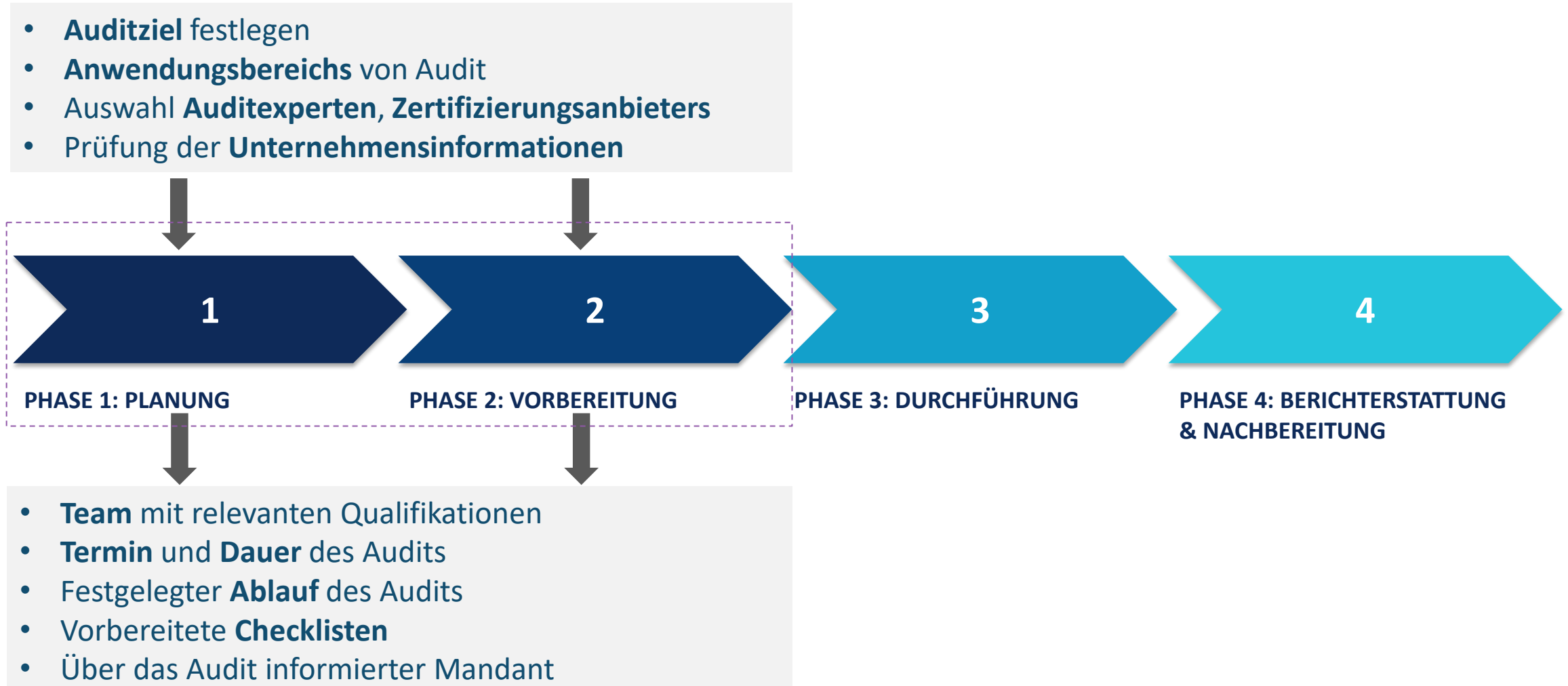
Stage II Audit: Praxis & Umsetzung

Fokus: Wird das System in der Realität gelebt?

- **Aktivität:** **Vor-Ort-Überprüfung** der Übereinstimmung zwischen **dokumentierter Darstellung und tatsächlicher Umsetzung**
- **Prüfmethode:** Interviews mit Mitarbeitern, Betriebsbegehungen, Stichproben von Aufzeichnungen

1. **Audit-Grundlagen**
2. **Vorbereitung und Planung**
3. **Audit Durchführung**
4. **Berichtserstattung im Auditprozess**
5. **Nichtkonformitäten**
6. **Zusammenfassung**

8.2. Vorbereitung und Planung mit ISO 22301



8.2. Vorbereitung und Planung mit ISO 22301

Planungstätigkeiten im Rahmen eines Zertifizierungsaudits

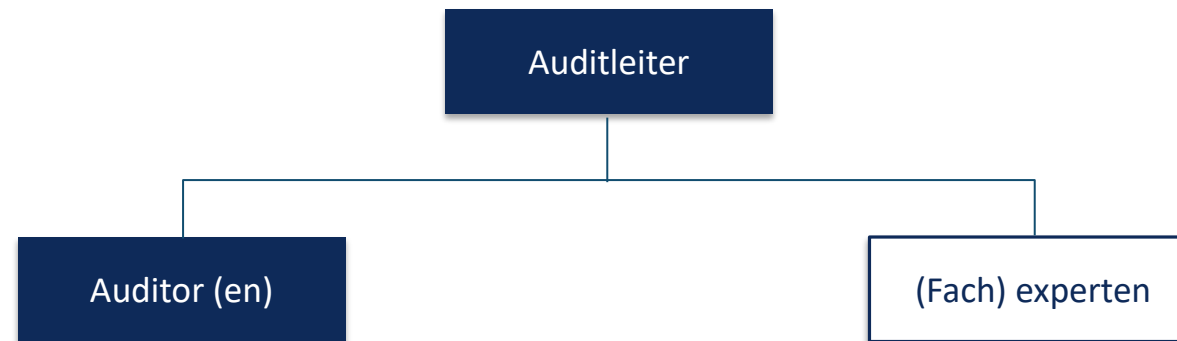
Folgende Aufgaben stehen an nach dem der Auditauftrag angenommen wurde:

- Abstimmung über den **Umfang** des Audits und den **Zeitpunkt** der Durchführung (eventuell bereits in der Angebotsphase)
- **Auswahl der Auditoren im Auditteam**, die das Zertifizierungsaudit durchführen werden (hier werden die erforderlichen Kompetenzen und Fachkenntnisse berücksichtigt)
- Erstellung eines **detaillierten Auditplans** für das Zertifizierungsaudit
 - Festlegung der Auditbereiche
 - Festlegung der benötigten Zeit für jeden zu auditierenden Bereich oder Auditee
 - Sicherstellung der Verfügbarkeit und Effektivität während des Audits
 - Auswahl der geeigneten Auditmethoden
 - Interviews
 - Begehungen
 - Überprüfung von Dokumentationen

8.2. Vorbereitung und Planung mit ISO 22301

Auditteam-Zusammensetzung

- Auswahl des Teams muss alle **fachlichen und methodischen Qualifikationen** kosteneffizient abdecken



ERFORDERLICHE KERNKOMPETENZEN

- RECHTLICHES & BEHÖRDLICHES WISSEN
- ISO 22301 NORM-VERSTÄNDNIS
- MANAGEMENT SYSTEMS AUDIT ERFAHRUNG
- FACHSPEZIFISCHER BCM-HINTERGRUND
- BRANCHENSPEZIFISCHES SEKTOR-WISSEN

8.2. Vorbereitung und Planung mit ISO 22301

Auditteam-Zusammensetzung

- Das Auditteam, das von der Zertifizierungsstelle zusammengestellt wird, setzt sich in der Regel aus dem **Auditleiter**, den **Auditoren** und **gegebenenfalls den Experten** zusammen. Bei der Auswahl der Teammitglieder sind bestimmte Kriterien und Kompetenzen zu berücksichtigen.
- **Kompetenzen der Auditteammitglieder:**
 - **Recht:** Rechtliches und behördliches Wissen, also Verständnis relevanter Gesetze, Vorschriften und behördlicher Anforderungen
 - **Normen:** ISO-22301-Verständnis sowie praktische Erfahrung mit Audits von Managementsystemen
 - **Branchenwissen:** Kenntnis des Unternehmenssektors und seiner spezifischen Herausforderungen, Risiken und Geschäftsprozesse
 - **Fachwissen:** BCM-Hintergrund sowie Verständnis von Notfallmanagement und Krisenbewältigung
 - **BCM-Methodik:** Kompetenz in BIA-, Risk Assessment und Risikomanagementmethoden

8.2. Vorbereitung und Planung mit ISO 22301

Aufgaben und Verantwortlichkeiten im Team bei Audits

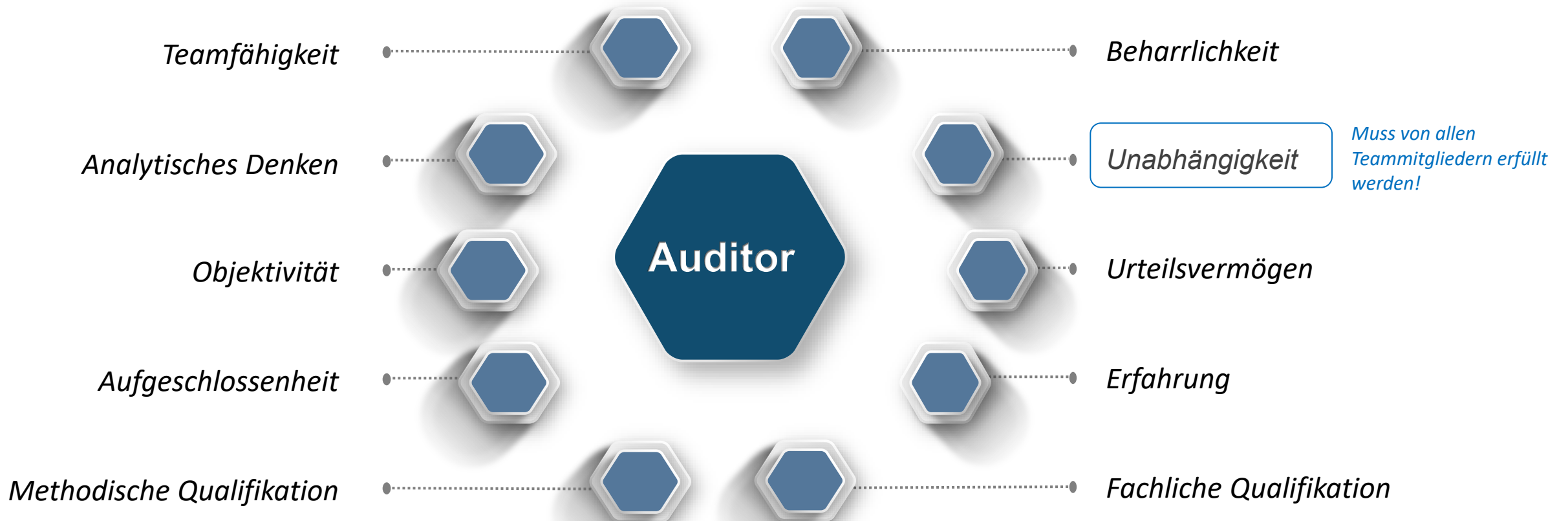
Auditleiter	Auditor	(Fach) experte
• leitet und verantwortet das Audit • erstellt den Auditplan in Absprache mit dem Kunden • dokumentiert und bewertet die Auditfeststellungen in Zusammenarbeit mit dem Team • präsentiert die Auditergebnisse (Zwischen- und Abschlussgespräch) • führt Nachaudits bei Abweichungen und Nebenabweichungen durch • erstellt und übermittelt den Auditbericht an die Zertifizierungsstelle	• bereitet sich auf das Audit vor, indem er relevante Unterlagen studiert • beteiligt sich an der Vorbegutachtung • führt allein oder gemeinsam mit anderen Teilaudits durch • dokumentiert seine Auditfeststellungen • arbeitet bei der Bewertung der Auditfeststellungen im Team mit • trägt zur Berichterstattung bei.	• bereitet auf das Audit vor: Studium der relevanten Unterlagen • wirkt fachlich unterstützend bei Teilaudits mit • zeichnet Auditfeststellungen auf • wirkt bei der Abstimmung im Team mit

8.2. Vorbereitung und Planung mit ISO 22301

Auswahl des Teams

- Bestimmte notwendige Qualifikationen und Eigenschaften von Auditoren und Auditleitern .

Quelle: Angepasste Darstellung nach Quellen: Gietl, G. & Lobinger, W. (2004). Leitfaden für Qualitätsauditoren. Planung und Durchführung von Audits nach ISO 9001:2000. S. 69, ISO 27006:2007



8.2. Vorbereitung und Planung mit ISO 22301

Erstellung des Auditplans

- Der Auditplan dient dazu, das **Vorgehen und die Aktivitäten des Audits festzulegen**, um die Auditziele zu erreichen.
- Der Auditplan **enthält wichtige Informationen und Maßnahmen**, die für den reibungslosen Ablauf des Audits erforderlich sind.
- **Wesentliche Bestandteile eines Auditplans** sind:
 - **Scope des Audits:** Der Umfang des Audits, der definiert, welche Bereiche des BCM-Systems geprüft werden.
 - **Datum und Dauer der Aktivitäten:** Festlegung des Zeitraums, in dem das Audit durchgeführt wird.
 - **Aktivitäten:** Die zu prüfenden Abschnitte des BCMS oder die spezifischen Anforderungen, die überprüft werden sollen.
 - **Rollen und Verantwortlichkeiten:** Festlegung der Verantwortlichkeiten der beteiligten Personen und Teams während des Audits.
 - **Meetings:** z.B. das Eröffnungsmeeting, wo Zweck und Ablauf des Audits den Beteiligten erklärt werden.

8.2. Vorbereitung und Planung mit ISO 22301 - Zusammenfassung

Checkliste (Teil 1)

- Wichtigsten Punkten zur Vorbereitung und Planung eines Zertifizierungsaudits im Bereich eines BCMS



- 1. Kontaktpersonen:** Erfassung der Namen und Kontaktdaten der Ansprechpartner für das Audit
- 2. Guides:** Bereitstellung von Leitfäden und Anleitungen für die Auditoren
- 3. Dolmetscher (falls notwendig):** Prüfung der Notwendigkeit eines Dolmetschers bei internationalen Audits
- 4. Verfügbarkeit** von Einrichtungen: Sicherstellung der Verfügbarkeit geeigneter Räumlichkeiten für das Audit
- 5. Gesundheits- und Sicherheitsvoraussetzungen:** Überprüfung, ob die erforderlichen Gesundheits- und Sicherheitsstandards erfüllt sind
- 6. Benötigte Ausrüstung für spezielle Bereiche:** Ermittlung spezieller Ausrüstung, die für bestimmte Bereiche des Audits benötigt wird
- 7. Sicherheitsüberprüfung:** Prüfung von Sicherheitsmaßnahmen und Zugangsberechtigungen für sensible Bereiche
- 8. Vertraulichkeitsvereinbarung:** Abschluss einer Vertraulichkeitsvereinbarung zwischen dem Unternehmen und den Auditoren

8.2. Vorbereitung und Planung mit ISO 22301 - Zusammenfassung

Checkliste (Teil 2)

- Wichtigsten Punkten zur Vorbereitung und Planung eines Zertifizierungsaudits im Bereich eines BCMS



- 9. Zahl der Mitarbeiter / Schichten:** Feststellung der Anzahl der Mitarbeiter und Arbeitszeiten, die während des Audits betroffen sind
- 10. Zahl der Standorte:** Berücksichtigung von mehreren Standorten und deren Einbindung in das Audit
- 11. Größe des Betriebes:** Bewertung der Unternehmensgröße und -struktur im Hinblick auf das Audit
- 12. Komplexität des Unternehmens:** Einschätzung der Komplexität der Geschäftsprozesse und -strukturen für das Audit
- 13. Gesetzgebung:** Beachtung der relevanten gesetzlichen Bestimmungen und Vorschriften
- 14. Größe des Auditteams:** Festlegung der Anzahl der Auditoren, die für das Audit benötigt werden
- 15. Qualifikation der Teammitglieder:** Sicherstellung, dass die Auditoren über die erforderlichen Qualifikationen und Erfahrungen verfügen
- 16. Zutritt zu Hochsicherheitsbereichen:** Klärung der Zugangsberechtigung zu hochsensiblen Bereichen während des Audits

1. **Audit-Grundlagen**
2. **Vorbereitung und Planung**
3. **Audit Durchführung**
4. **Berichtserstattung im Auditprozess**
5. **Nichtkonformitäten**
6. **Zusammenfassung**

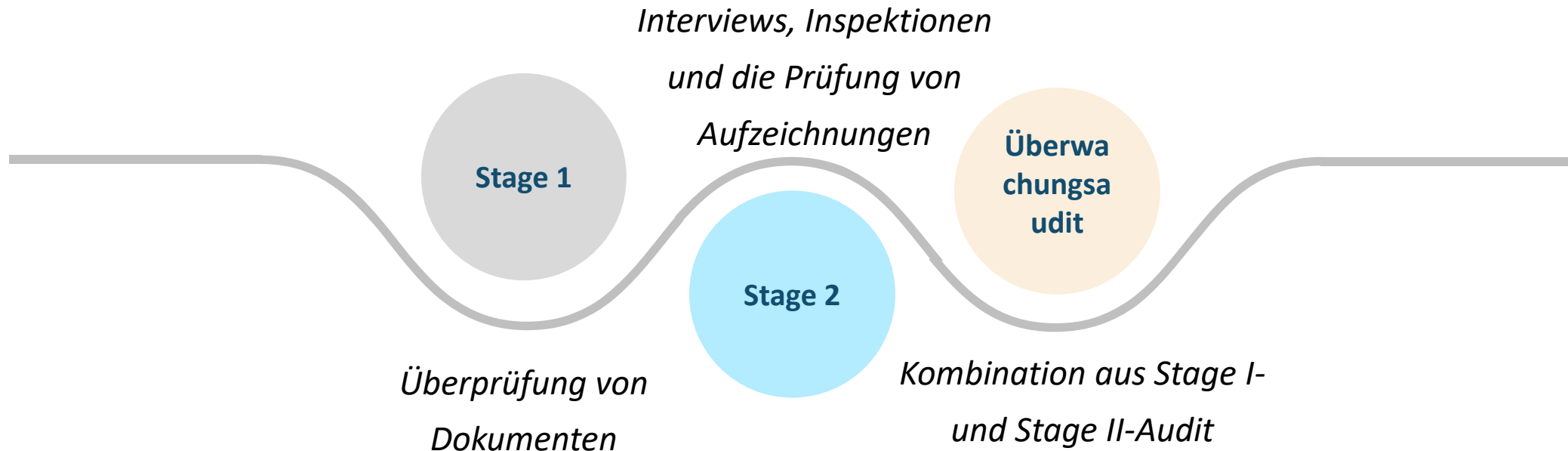
8.3. Audit Durchführung



8.3. Audit Durchführung

Durchführung des Audits

- Eigentliche Umsetzung des Audits hat zum Ziel **sicherzustellen, dass alle relevanten Bereiche des Unternehmens im Rahmen des Business Continuity Management Systems (BCMS) erfasst werden.**
- Durchführung variiert je nachdem, ob es sich um ein **Stage I-, Stage II- oder Überwachungsaudit** handelt.



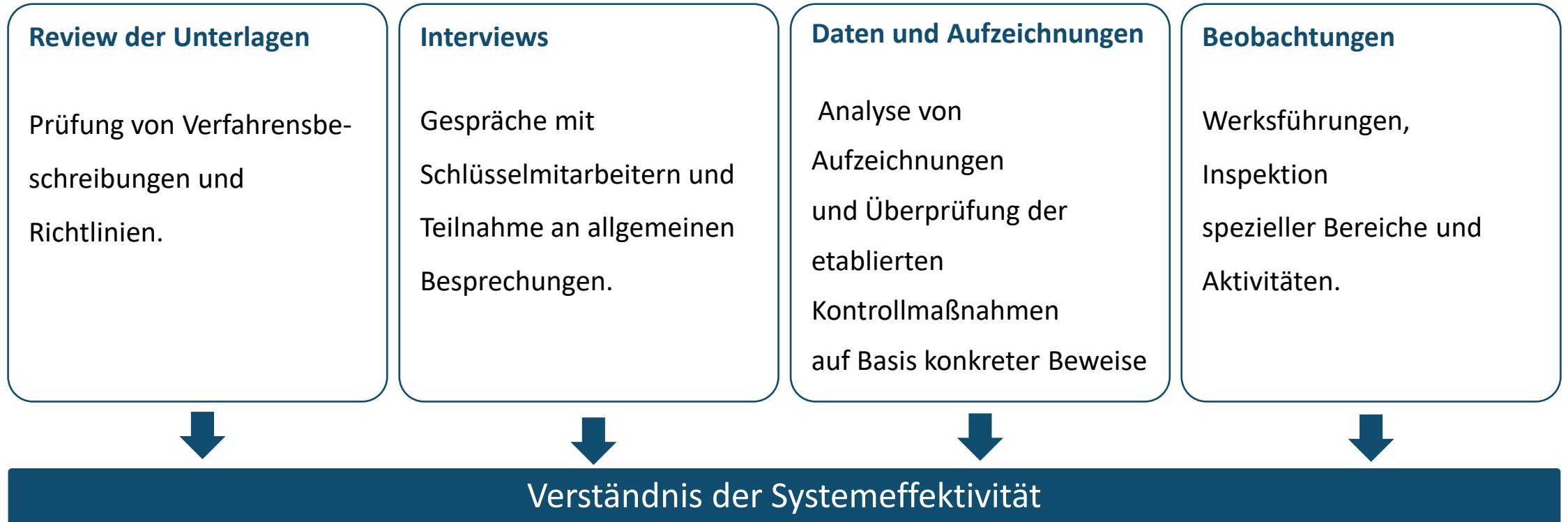
8.3. Audit Durchführung

Durchführung des Audits

- Die Auditdurchführung besteht im Wesentlichen aus folgenden Schritten:
 - **Eröffnungsmeeting:** Beginn des Audits, Vorstellung der Auditoren und Klärung der Ziele und Vorgehensweise
 - **Dokumentenreview** (Stage I, gegebenenfalls auch Stage II): Überprüfung der vorhandenen Dokumentationen und Richtlinien
 - **Durchführung von Interviews** (Stage II): Befragung von Mitarbeitern und Verantwortlichen, um Informationen und Einblicke zu gewinnen
 - **Begehungen** (Stage II): Inspektion von betrieblichen Bereichen – prüft die Umsetzung von BCM-Maßnahmen
 - **Review von Aufzeichnungen** (Stage II): Überprüfung von Aufzeichnungen und Protokollen, um die Wirksamkeit des BCMS zu bewerten
 - **Abschlussmeeting:** Zusammenfassung der Audit-Ergebnisse, Diskussion offener Punkte und Festlegung von Handlungsempfehlungen

8.3. Audit Durchführung

Durchführung des Audits – Vier Hauptmethoden

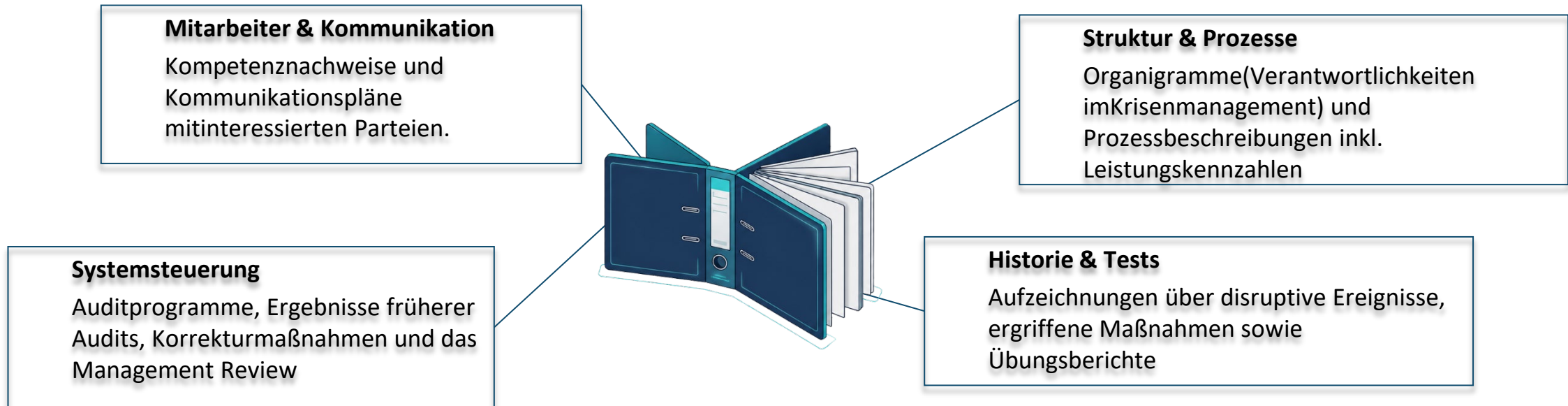


Wirksamkeit entsteht erst durch das Zusammenspiel der Methoden.

8.3. Audit Durchführung – Stage I

Ablauf des Stage I Audits

- Stage I Audits legt den **Schwerpunkt auf der Überprüfung aller relevanten Dokumente, die im Zusammenhang mit der Entwicklung, Implementierung, Überwachung und Verbesserung BCMS erstellt und gepflegt werden.**
- **Auditee ist verantwortlich für die Bereitstellung der folgenden Dokumente:**



8.3. Audit Durchführung – Stage I

Ablauf des Stage I Audits

- **Auditee ist verantwortlich für die Bereitstellung der folgenden Dokumente:**
 - Rechtliche, regulatorische und andere Anforderungen
 - Geltungsbereich des BCMS (Scope) und Erklärung der Ausschlüsse
 - Business Continuity Leitlinie
 - Business Continuity Ziele
 - Business Continuity Pläne und Verfahren inklusive Verfahren zu Warnung und Kommunikation und
 - Verfahren zur Wiederherstellung und Rückführung von Aktivitäten

8.3. Audit Durchführung – Stage I

Ablauf des Stage I Audits (Forts.)

– **Auditee ist verantwortlich für die Bereitstellung der folgenden Dokumente:**

- Kompetenzen der Mitarbeiter
- Kommunikation mit interessierten Parteien inkl. nationalen oder regionalen Risikoberatungssystemen
- Aufzeichnungen über das disruptive Ereignis, ergriffene Maßnahmen und getroffene Entscheidungen
- Übungsberichte
- Ergebnisse der Überwachungen, Messungen, Analysen und Bewertungen des BCMS
- Auditprogramm
- Auditergebnisse
- Ergebnisse der Überprüfung durch das Management (Management Review)
- Eigenschaften von Nichtkonformitäten und Korrekturmaßnahmen
- Ergebnisse der Korrekturmaßnahmen

8.3. Audit Durchführung – Stage I

Ablauf des Stage I Audits (Forts.)

– **Auditee ist verantwortlich für die Bereitstellung der folgenden Dokumente:**

- **Organigramme:**
 - Abbildung der Unternehmensstruktur mit den Namen und Rollen der wichtigsten Funktionsträger
 - Zeigt die Verantwortlichkeiten und Zuständigkeiten im Krisen- und Notfallmanagement auf
- **Prozessbeschreibungen und Leistungskennzahlen:**
 - Dokumentation der Geschäftsprozesse mit detaillierten Ablaufbeschreibungen
 - Einschätzung der Leistungskennzahlen zur Bewertung der Geschäftskritikalität der Prozesse
- **Lage- und Gebäudepläne:**
 - Visualisierung der Standorte, Räumlichkeiten und Infrastruktur des Unternehmens
 - Enthält Pläne von Rechenzentren, Serverräumen, Netzwerkräumen, Datenträgerarchiven sowie der versorgungs- und sicherheitstechnischen Infrastruktur

8.3. Audit Durchführung – Stage I

Ablauf des Stage I Audits (Forts.)

- **Auditee ist verantwortlich für die Bereitstellung der folgenden Dokumente:**
 - **Übersicht über die IT-Landschaft:**
 - Darstellung der IT-Systeme, Anwendungen, Datenbanken und deren Abhängigkeiten
 - Zeigt die IT-Infrastruktur und -Ressourcen, die für den Geschäftsbetrieb relevant sind
 - **Weitere ergänzende Dokumente:**
 - Je nach Unternehmenskontext können weitere Informationen und Dokumente erforderlich sein, z.B. Notfallpläne, Kommunikationspläne, Versicherungsdokumente, etc.

**Ohne Nachweise bleibt Wirksamkeit
Behauptung**

8.3. Audit Durchführung – Stage II

Fragetechniken im BCSM

Best Practices

- **Offene Fragen stellen:** Ermutigt den Auditee zu ausführlichen, un gelenkten Antworten.
- **Auf Augenhöhe agieren:** Eine respektvolle, offene Kommunikationsebene aufrechterhalten, um Vertrauen zu schaffen.
- **Praxisbezug suchen:** Die tatsächliche Umsetzung im Alltag hinterfragen.

Audit-Fehler

- **Verkettungsfragen vermeiden:** Niemals Fragen stellen, bei denen die gewünschte Antwort bereits in der Frage enthalten ist (suggestiv).
- **Reine Ja/Nein-Abfragen:** Verhindert tiefere Einblicke in komplexe Prozessabläufe.

8.3. Audit Durchführung – Stage II

Fragetechniken im BCSM (Forts.)

- **Fragen in chronologischer Reihenfolge:** Stellen Sie Fragen, die der Abfolge der Ereignisse folgen.
- **Nachfragen und Hypothesen:** Seien Sie nicht zurückhaltend, um weitere Informationen zu erlangen.
Stellen Sie hypothetische Fragen wie "Was, wenn...?" und bitten Sie den Auditee, Ihnen zu zeigen, wie, wo, wann oder warum etwas geschieht.
- **Kein Drängen zur Antwort:** Geben Sie dem Auditee Zeit, um zu antworten, und drängen Sie ihn nicht zu einer bestimmten Antwort.
- **Offensichtliche Fragen:** Haben Sie keine Angst, Fragen zu stellen, die offensichtlich erscheinen.
Manchmal können sie wichtige Informationen offenbaren.
- **Überprüfung vager Antworten:** Wenn eine Antwort vage oder zweideutig ist, gehen Sie im Auditablauf vor oder zurück, um die Richtigkeit zu überprüfen.

8.3. Audit Durchführung – Stage II

Fragetechniken im BCSM (Forts.)

- **Verkettungsfragen vermeiden:** Stellen Sie keine Fragen, bei denen die Antwort bereits in der Frage enthalten ist.
- **Offene Fragen:** Verwenden Sie offene Fragen, die den Auditee ermutigen, ausführliche Antworten zu geben.
- **Augenhöhe:** Führen Sie die Interviews auf "Augenhöhe" durch, indem Sie eine respektvolle und offene Kommunikationsebene aufrechterhalten.

8.3. Audit Durchführung – Nachweise

Evidenzbasierter Nachweis

– **Objektivität:**

- Feststellungen basieren auf Fakten und werden ohne persönliche Gefühle, Vorurteile oder Interpretationen ausgedrückt.
- Gewährleistung der klaren Kommunikation und Übereinstimmung mit den Gesprächspartnern des Unternehmens.

– **Nachweis:**

- Bereitstellung äußerer Zeichen oder Beweise, die die Feststellungen unterstützen.
- Beispiele für Nachweise können Aufzeichnungen, das Fehlen von Aufzeichnungen oder mangelndes Wissen und Bewusstsein sein.

– **Dokumentation:**

- Alle positiven und negativen Feststellungen, einschließlich Abweichungen, Nebenabweichungen und Beobachtungen, müssen von den Auditoren dokumentiert werden.
- Die Dokumentation kann in Form von Audit-Checklisten, Audit-Notizen, Abweichungsberichten usw. erfolgen.

8.3. Audit Durchführung – Stichproben

– Bewertung der Konformität und Überzeugungs niveau:

- Keine vordefinierten Stichprobenpläne
- In der Regel keine statistischen Methoden
- Basierend auf der Einschätzung und Erfahrung des Auditors
- Bei hohem Risiko: Größere Stichprobe erforderlich

– Der Auditor muss in der Lage sein zu verstehen:

- Was zeigt das Beispiel?
- Besteht Konsistenz mit anderen Nachweisen?
- Bestätigt es Übereinstimmung oder Abweichung?
- Gibt es Anzeichen für notwendige Recherchen in anderen Bereichen?
- Wurde das Risiko zufriedenstellend reduziert?

1. **Audit-Grundlagen**
2. **Vorbereitung und Planung**
3. **Audit Durchführung**
4. **Berichtserstattung im Auditprozess**
5. **Nichtkonformitäten**
6. **Zusammenfassung**

8.4. Berichterstattung im Zertifizierungsprozess



8.4. Berichterstattung im Zertifizierungsprozess

Auswahl des Teams

- Bestimmte notwendige Qualifikationen und Eigenschaften von Auditoren und Auditleitern
- Nicht jeder kann einen Auditbericht erstellen
- Es braucht **Erfahrung, Fachkompetenz** und ein **gutes Urteilsvermögen**

1. **Audit-Grundlagen**
2. **Vorbereitung und Planung**
3. **Audit Durchführung**
4. **Berichtserstattung im Auditprozess**
5. **Nichtkonformitäten**
6. **Zusammenfassung**

8.5 Nichtkonformitäten

Definition

Feststellung

Eine Tatsache oder ein Ereignis, das potenziell positive oder negative Auswirkungen auf das Managementsystem haben kann.

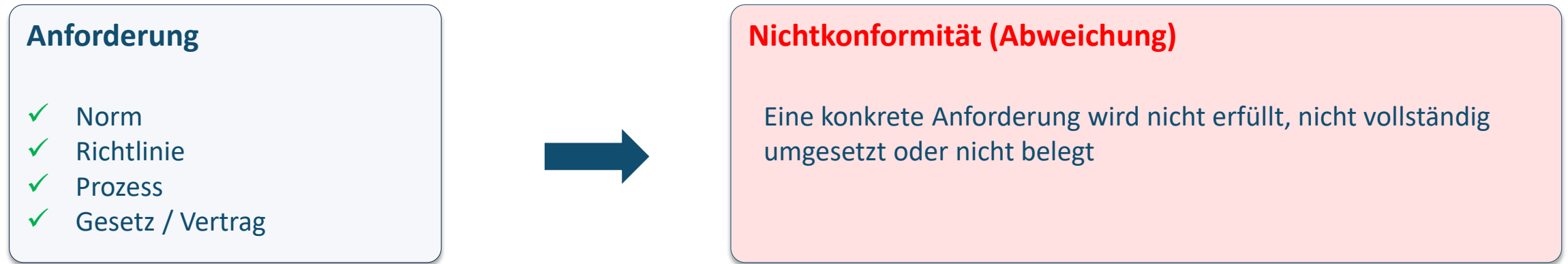
- Feststellungen können auch dann verwendet werden, wenn Hinweise darauf hinweisen, dass bestimmte Bereiche Schwachstellen aufweisen, jedoch kein objektiver Nachweis vorliegt, um dies zu bestätigen.

- **Beispiele für Feststellungen:**
 - Es ist geplant, das Rechenzentrum im kommenden Geschäftsjahr in ein neues Gebäude zu verlegen.
 - Die Überarbeitung der Business Continuity Policy ist innerhalb der nächsten vier Wochen geplant.

8.5 Nichtkonformitäten

Was ist eine Nichtkonformität?

- **Feststellungen** (engl. *Findings*) entstehen nicht durch Eindruck, sondern nachweisbare Nichterfüllung einer konkreten Anforderung



Nichtkonformität = Anforderung + tatsächliche Abweichung + objektiver Nachweis

- **Anforderung:** Was hatte erfüllt sein müssen?
- **Tatsache:** Was wurde tatsächlich vorgefunden?
- **Nachweis:** Womit wird die Feststellung belegt?

8.5 Nichtkonformitäten

Nichtkonformitäten

- Nicht jede Feststellung ist sofort eine Nichtkonformität

- 1. **Beobachtung / Observation / Empfehlung:** Hinweise auf Bereiche, in denen zwar keine direkte Anforderung verletzt wurde, aber eine Optimierung zur Steigerung der Effizienz oder Risikominimierung dringend empfohlen wird.
 - Beispiel: „Das Rechenzentrum soll nächstes Jahr umziehen.“

- 2. **Nichtkonformität / Abweichung:** nachweisbarer Verstoß gegen Anforderungen. Hier ist zwingend ein Nachweis der Wirksamkeitsprüfung für Korrekturmaßnahmen erforderlich
 - Beispiel: „Laut BCMS-Richtlinie muss jährlich eine Krisenübung durchgeführt werden. Für das aktuelle Jahr liegt kein Übungsbericht vor.“

8.5 Nichtkonformitäten

Nichtkonformitäten

- Ein gutes *Finding* ist präzise, sachlich, nachvollziehbar, eindeutig formuliert mit objektiven Beweisen

6 W-Fragen der Dokumentation:



8.5 Nichtkonformitäten

Nichtkonformitäten – Arten

- Die Einstufung entscheidet über Dringlichkeit und Zertifizierungsfähigkeit

Minor · geringfügige Abweichung

Einzelne Anforderung nicht erfüllt, aber kein systematisches Versagen des gesamten BCMS.

Typische Beispiele:

- fehlende Versionsnummer in einem Dokument
- einzelner Schulungsnachweis fehlt
- unvollständiges Protokoll

Major · signifikante Abweichung

Zentrales Element fehlt oder die Wirksamkeit des BCMS ist ernsthaft gefährdet.

Typische Beispiele:

- keine Risikoanalyse
- keine internen Audits
- keine Managementbewertung
- Notfallpläne nie getestet

Eine Zertifizierung gemäß ISO 22301:2020 ist nicht möglich, wenn eine bedeutende Abweichung (Major) festgestellt wurde.

8.5 Nichtkonformitäten

Gründe für Abweichungen können sein:

- **Unklare Verantwortung:** Rollen, Eskalation oder Freigaben sind nicht eindeutig geregelt.
- **Fehlende Schulung:** Mitarbeitende kennen Verfahren oder Notfallrollen nicht.
- **Ressourcenmangel:** Zeit, Budget oder Personal reichen für wirksame Umsetzung nicht aus.
- **Papier ≠ Praxis:** Dokumentierte Vorgaben passen nicht zur gelebten Realität.
- **Schwache Nachweisführung:** Aktivitäten finden statt, werden aber nicht auditfest dokumentiert.
- **Management-Lücke:** Priorisierung, Freigaben oder Review durch Leitung fehlen.

8.5 Nichtkonformitäten

Nichtkonformitäten – Ermittlung

- Nichtkonformitäten werden während der Durchführung der Zertifizierung erkannt und müssen protokolliert werden.
- Es ist erforderlich, die objektiven Beweise für jede Nichtkonformität im Detail zu beschreiben.
- Befolgen Sie dabei die folgenden Schritte:
 - Sammeln Sie alle relevanten Beweismittel.
 - Analysieren Sie die während des Audits gesammelten Beweise und untersuchen Sie die festgestellten Beobachtungen.
 - Stellen Sie sicher, dass alle Fakten solide und gut begründet sind.
 - Teilen Sie etwaige Bedenken entweder dem geprüften Unternehmen oder dem Audit-Teamleiter mit.
 - Klassifizieren Sie die Nichtkonformitäten und stellen Sie sicher, dass keine signifikanten Trends erkennbar sind.
 - Machen Sie klare und prägnante Anmerkungen zu den spezifischen Beobachtungen, indem Sie das Wann, Wo, Was, Warum, Wer und Wie festhalten



8.5 Nichtkonformitäten

Ursachen für Nichtkonformitäten

- Gründe für Abweichungen können sein:
 - Fehlende Übereinstimmung zwischen aktuellen Praktiken und schriftlichen Richtlinien/Verfahren
 - Mangelnde Umsetzung schriftlicher Richtlinien/Verfahren in der Praxis
 - Unwirksame Umsetzung der Praktiken
 - Unzureichende Berücksichtigung von Risiken, die zu Betriebsunterbrechungen führen könnten

8.5 Nichtkonformitäten

Korrektur Schleife

**1. Ursachenanalyse
(Auditee)**
Analyse der Wurzel des Problems basierend auf der Verbesserungsnotiz.



**3. Freigabe
(Zertifizierungsstelle)**
Bewertung und Akzeptanz der vorgeschlagenen Maßnahmen durch die Auditoren.

8.5 Nichtkonformitäten

Der 3-Schritte-Plan

- Nicht nur den Fehler beheben, sondern die Ursache beseitigen
-
1. **Ursachenanalyse (Root Cause Analysis - RCA):** Erfahrene Auditoren wissen: BCM-Fehler sind selten reine Prozessfehler, sondern oft Ressourcen-Kultur-Fehler. Die RCA muss klären, warum z.B. Supportprozesse ignoriert wurden oder warum Abhängigkeiten nicht dokumentiert wurden.
 2. **Korrekturmaßnahmen:** Sofortige Beseitigung der Lücke (z.B. Nachholen der BIA-Workshops unter Einbeziehung der Managementprozesse).
 3. **Wirksamkeitsprüfung:** Der entscheidende Schritt. Es muss objektiv nachgewiesen werden, dass die Maßnahme das Wiederauftreten verhindert. Ein erneuter Fehler im nächsten Zyklus deutet auf ein systemisches Managementversagen hin.

8.5 Nichtkonformitäten

Dokumentation von Nichtkonformitäten

- Wenn eine Abweichung festgestellt wird, ist es erforderlich, eine "**Verbesserungsnotiz**" (VN) zu erstellen, um die Abweichung zu dokumentieren. Das Teammitglied, das die Verbesserungsnotiz verfasst, muss sicherstellen, dass die zugrunde liegenden Unterlagen präzise und fehlerfrei sind.
- Die Verbesserungsnotiz umfasst folgende klare und präzise Informationen:
 - **Art der Nichtkonformität**
 - **Nachweise, die die Nichtkonformität unterstützen**
 - **Nicht erfüllte Anforderungen**
- Basierend auf der Verbesserungsnotiz fordert die Zertifizierungsstelle eine Analyse der Ursachen sowie eine Beschreibung der durchgeführten oder geplanten Korrekturmaßnahmen, um die identifizierten Abweichungen innerhalb eines festgelegten Zeitraums zu beheben.
- Die Zertifizierungsstelle ist verantwortlich für die Bewertung der vom Kunden vorgeschlagenen Korrekturmaßnahmen, um festzustellen, ob sie akzeptabel sind.

8.5 Nichtkonformitäten

Merkmale von "guten *Findings*":

- Präzise und eindeutige Formulierung
- Erfüllung der Kontrollanforderung oder Fragestellung in Bezug auf Qualität und Quantität
- Sachliche Darstellung ohne Interpretationsspielraum zwischen Absender und Empfänger
- Deutliche Unterscheidung zwischen Feststellung, Bewertung und Empfehlung
- Vermeidung absoluter oder kategorischer Formulierungen
 - Berücksichtigung sowohl negativer als auch positiver Aspekte
 - (Beschreibung dessen, was vorhanden ist und was nicht).

8.5 Nichtkonformitäten

Erstellung der Verbesserungsnotiz – „Improvement Note (IN)“:

- Die Verbesserungsnotiz sollte folgende Angaben enthalten:
 - Datum und Nummer des Audits sowie das Erstellungsdatum der Verbesserungsnotiz
 - Name des Unternehmens, der auditierten Abteilung oder des Bereichs
 - Bezug auf den Auditstandard – ISO 22301, Paragraphennummer und/oder Verfahrens-/Spezifikationsnummer, gegen die verstoßen wurde
 - Klassifizierung als geringfügige (Minor), wesentliche (Major) oder Beobachtung (Observation)
 - Deutliche Angabe der Art des Defizits
 - Name des Auditors, der die Nichtkonformität identifiziert hat

Nr	Datum	Klassifizierung	Paragraph	Auditor	Auditee	Nichtkonformität	Ursache und Korrekturmaßnahmen	Kommentar des Auditor
01							Wird vom Auditee befüllt	
02								

8.5 Nichtkonformitäten

Bericht über das Audit

- Nach Abschluss des Audits ist der Auditor verpflichtet, einen schriftlichen Bericht zu erstellen. Der Auditbericht muss präzise, knapp und klar sein, um der Zertifizierungsstelle eine fundierte Entscheidung zu ermöglichen.

8.5 Nichtkonformitäten

Bericht über das Audit

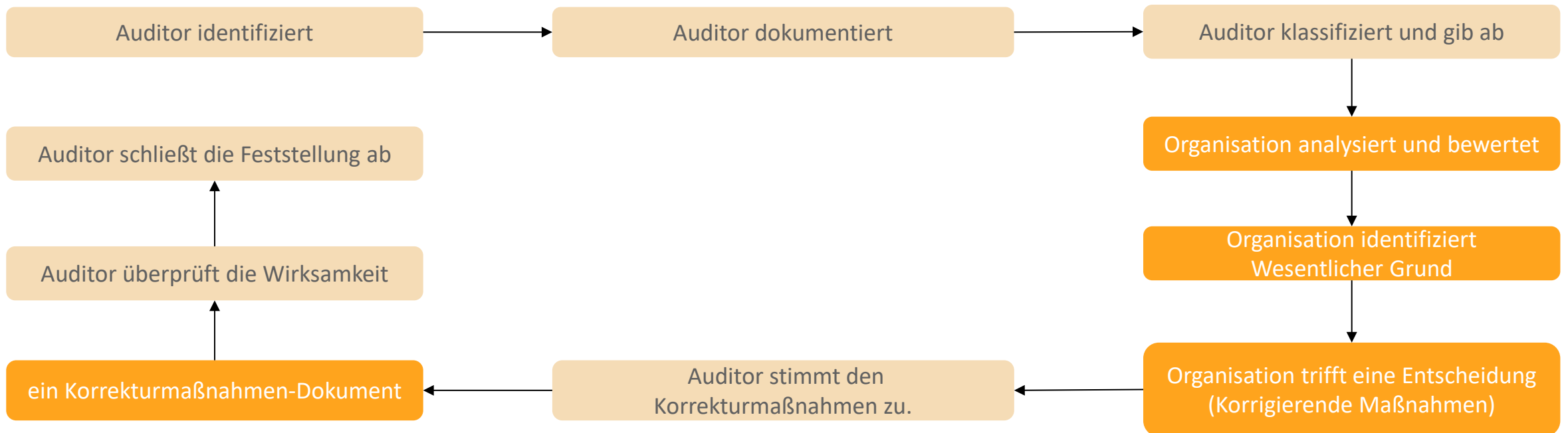
- Der Auditbericht umfasst folgende Aspekte:
 - Angabe der Zertifizierungsstelle
 - Ziele, Rahmenbedingungen, Art des Audits, Normgrundlage und Bezug zu den zugrunde liegenden Dokumenten
 - Geschäftszweck des Unternehmens
 - Geltungsbereich des Business Continuity Management Systems (BCMS)
 - Auditgrundlage (Verweis auf Referenzunterlagen, Checklisten)
 - Vorgehensweise (Methoden, Prüfdichte)
 - Auditteam sowie Termine und Orte, an denen die Auditaktivitäten durchgeführt wurden
 - Darstellung der positiven und negativen Feststellungen und Bewertungen zu allen geprüften Normanforderungen (Status, Hauptabweichungen/Nichtkonformitäten, geringfügige Abweichungen, Beobachtungen, Bezug zur Vorprüfung)
 - Gegebenenfalls Bewertung der während des Audits oder im Rahmen eines Nachaudits durchgeführten Korrekturmaßnahmen bei Hauptabweichungen/Nichtkonformitäten und geringfügigen Abweichungen
 - Gesamtbewertung des Auditteams zur Erfüllung der Norm (Empfehlung für oder gegen die Zertifizierung)

1. **Audit-Grundlagen**
2. **Vorbereitung und Planung**
3. **Audit Durchführung**
4. **Berichtserstattung im Auditprozess**
5. **Nichtkonformitäten**
6. **Zusammenfassung**

8.6. Zusammenfassung

Ablauf bei der Berichterstattung

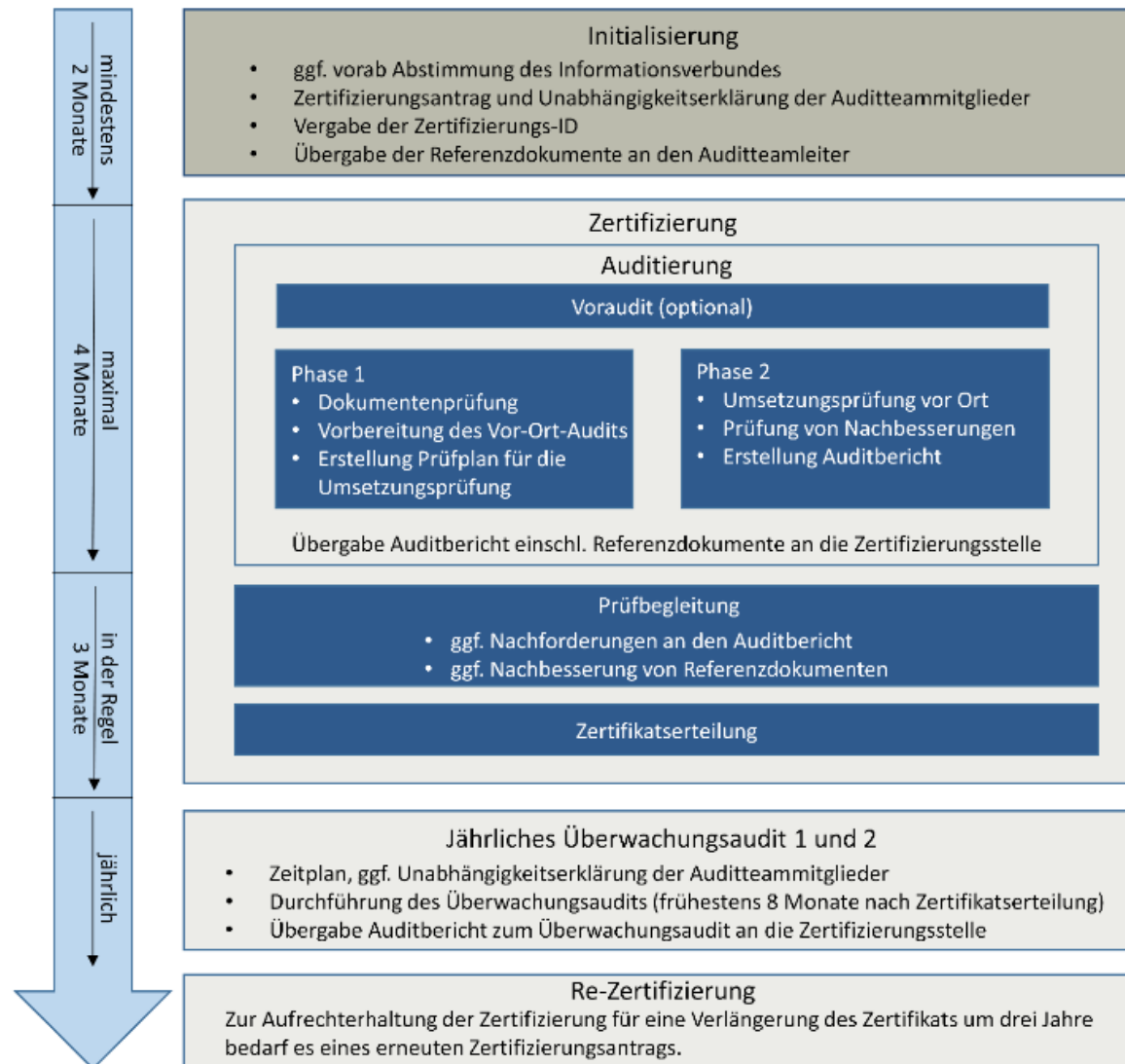
- Im abschließenden Schritt des vierstufigen Auditmodells folgt nun die Phase der Berichterstattung und Nachbereitung. Der generelle Ablauf **Organisation erstellt** der Berichterstattung sieht wie folgt aus:



8.6. Zusammenfassung

Ablauf Zertifizierungsprozess

Quelle: Darstellung nach Quellen: Auditierungsschema
Für ISO 27001-Zertifizierungen auf der Basis von IT-
Grundschutz
Version 2.5





Impressum

Prof. Dr. Gael Pentang

Cybersecurity Management

Gael.Pentang@hs-niederrhein.de